



Offensive Security Considered Offensive

Two decades of research, measured against where the threats actually are.

One corpus, checked against reality

- › One curated corpus: talkback.sh, 20,504 talks and 8,000+ classified papers (2005–2026)
- › Triangulated against CISA KEV, the Verizon DBIR, Google Project Zero, and grey-market pricing; conference data from citation.think.st; venture capital figures for bug bounties and SAST, Pwn2Own competition data
- › The gap between those sources is where the argument lives
- › Honest caveats: they are proxies with their own biases and limitations
- › My lens: elttam sells offensive security services and talkback.sh is our platform.
- › **This is a summary presentation due to time.**

The AI vulnerability storm

2.3 years → 9 hours

mean time from disclosure to exploitation, 2018 → 2026 · 3,533
CVE-and-exploit pairs

The acceleration is real. But it measures how fast known vulnerabilities get weaponised, not whether research is aimed at the ones that do.

The “AI Vulnerability Storm”: Building a “Mythos-ready” Security Program

Expedited Strategy Briefing

By the CSA CISO Community, SANS, [un]prompted, the OWASP Gen AI Security Project, and the wider community.

Contact cisos@cloudsecurityalliance.org with any inquiries.

16 April, 2026

Version 0.92

The latest version of this document can be found [here](#).



The industry follows incentives, not threats

The field grew enormously in output, funding, and visibility, without a matching improvement in defence. Not random, not anyone's fault: three structural forces pull research away from the threats.

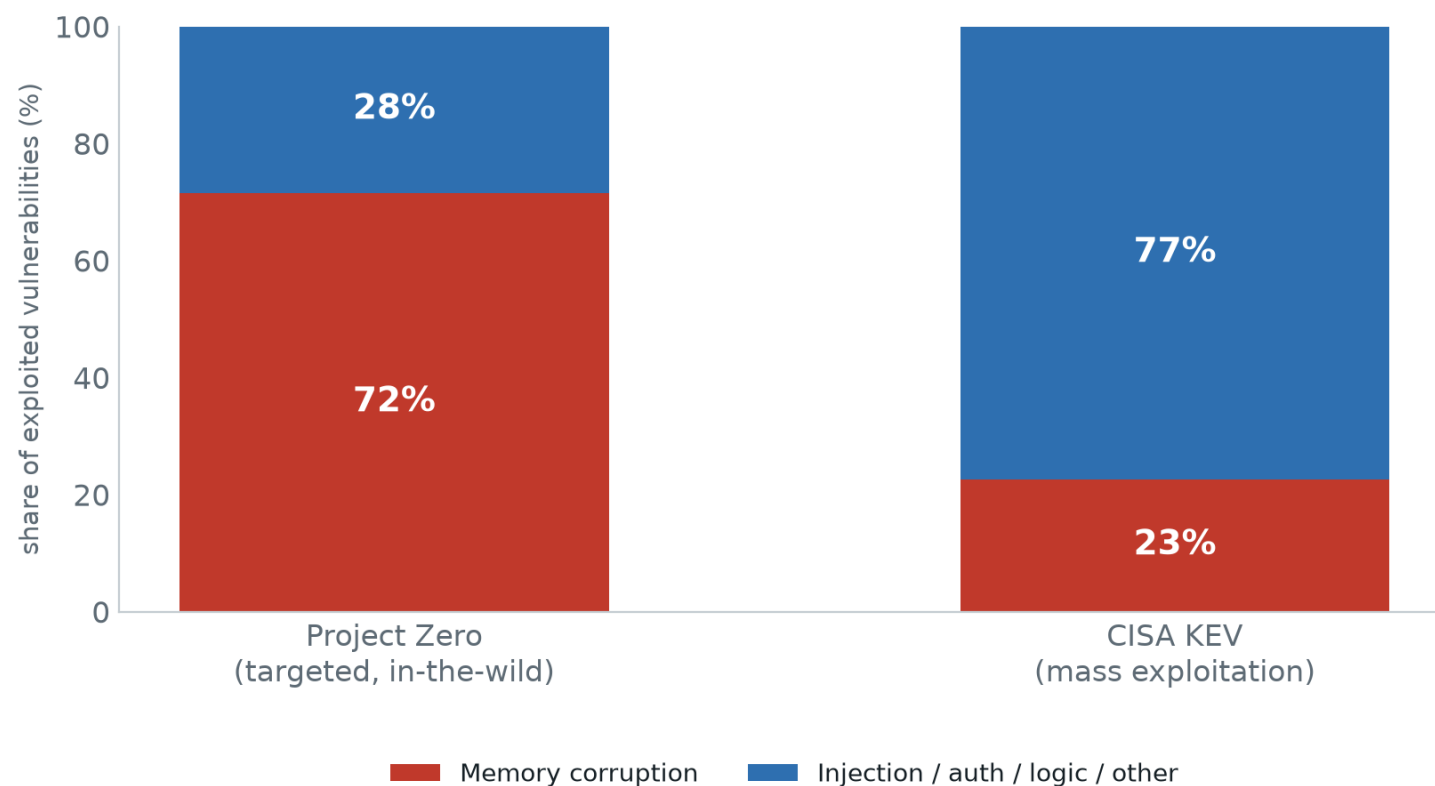
- › Venture capital and a fast-scaling commercial sector
- › The militarisation of offensive capability
- › The pull of the novel over the useful

How has two decades of publications, research, and tooling resulted in meaningful risk reduction?

e.g. Improving secure defaults, standards and mandates, limiting impact, or increasing exploit development cost

Two economies of exploitation

Targeted 0-days (Project Zero) vs mass-exploitation (KEV / DBIR): two structurally different populations.



Many vulnerability classes are old with long timelines

Research → tooling → propagation → mass exploitation. Insecure deserialisation (CWE-502) as the worked example.

Schoenefeld / Koivu

2006



~9 years dormant

NCC Group (.NET)

2017



2015



2018



IBM Aspera Faspex

2022



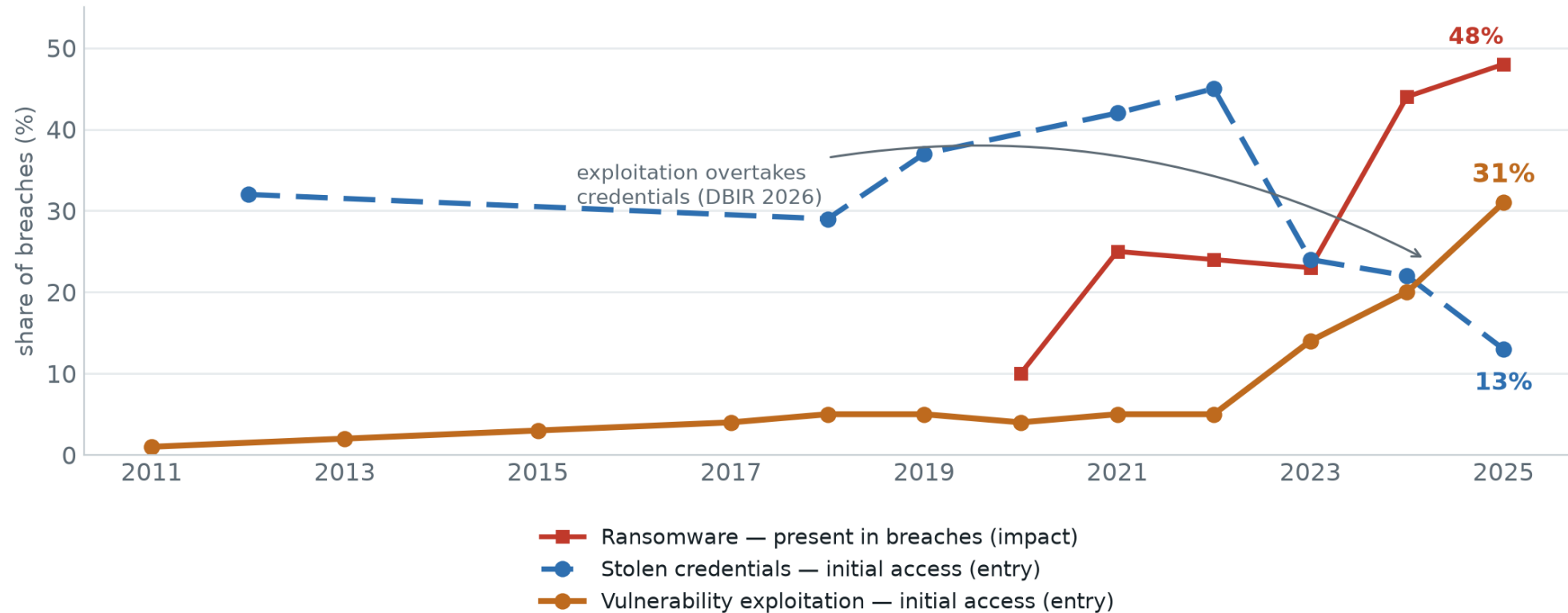
- research milestone
- mass weaponisation

ysoserial PHPGGC · elttam (Ruby)

Shown exploitable in the mid-2000s (JMX), then ~9 years dormant before ysoserial (2015) drove mass weaponisation by 2022.

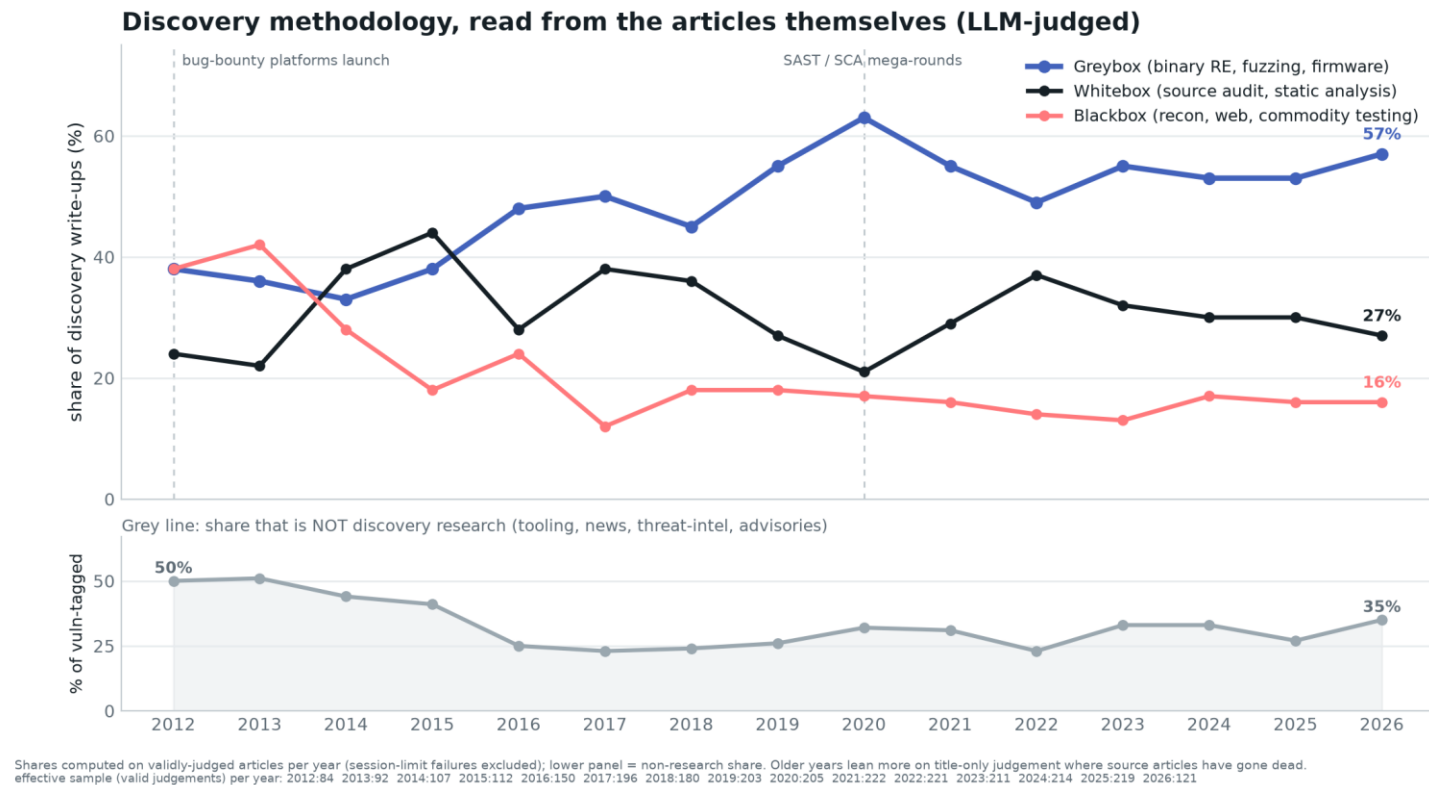
Initial access has changed

Exploitation as initial access rises 1%→31%, overtaking stolen credentials (45%→13%). Ransomware ~48%.



Venture capital influence on discovery methodology

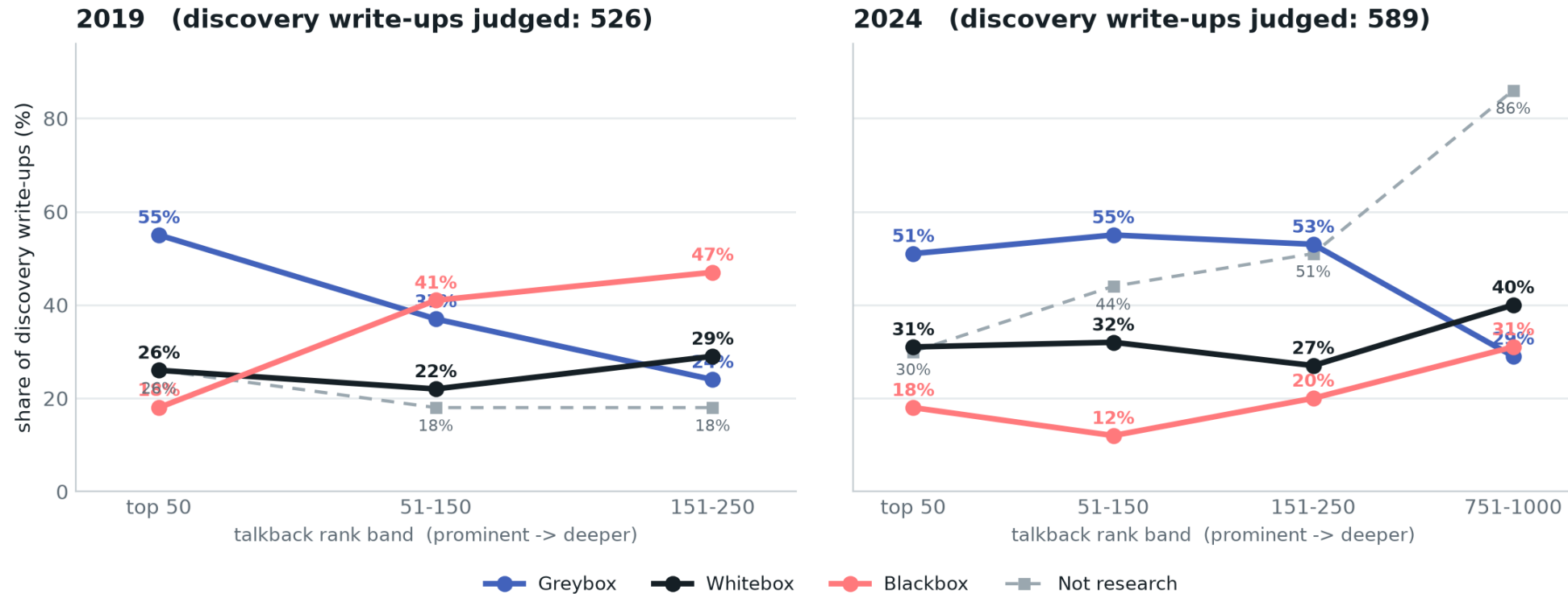
Billions in venture capital flowed into SAST/SCA tooling (Snyk alone \$1.3B) and the bug-bounty platforms (over \$0.5B) and appears to influence the methodologies of published vulnerabilities – bug bounties are blackbox, SAST is whitebox.



Popular and influential publications and research by methodology over 15 years

The prominent tier hides the tail and decline of blackbox

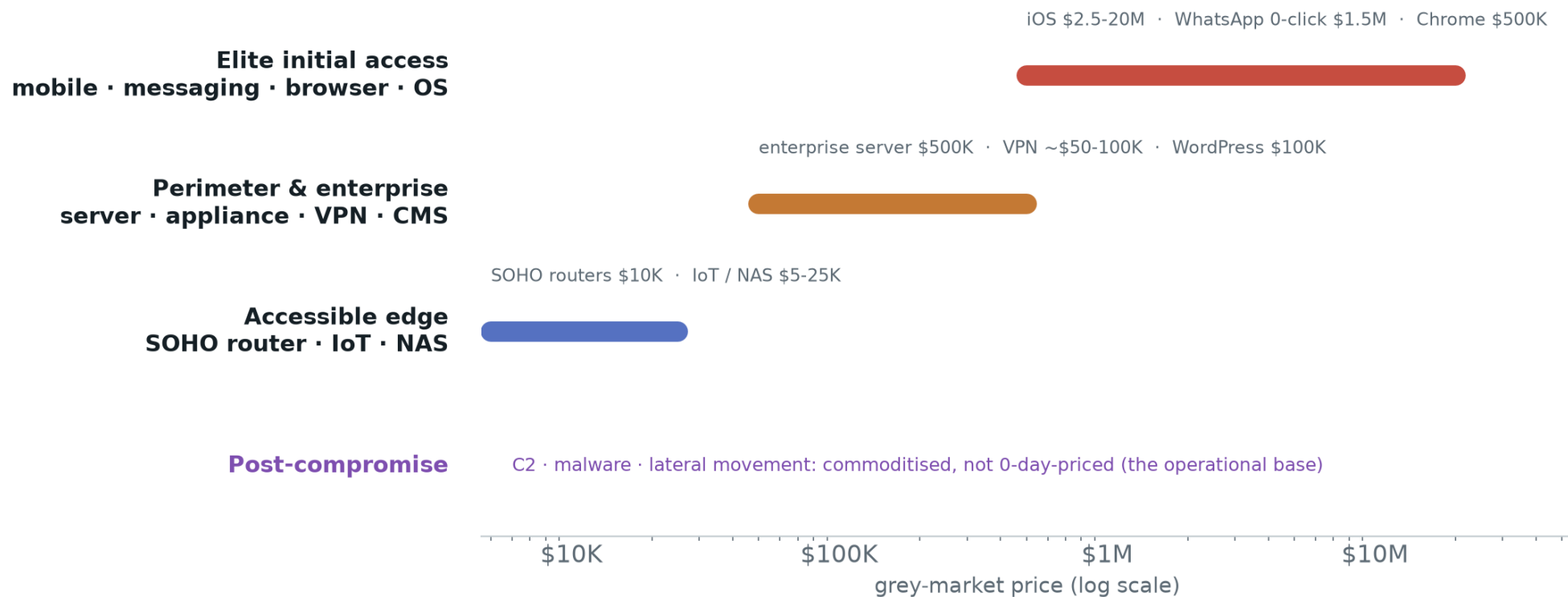
3% of all publications is the top 50. Sample deeper and it inverts: in 2019 blackbox climbs from **18%** of the prominent tier to **47% of the middle**, as greybox halves. In 2024 whitebox and graybox are more common, with blackbox dropping.



2019: sampling to rank ~50, blackbox climbs as prominence falls. 2024: sampling to rank ~35, greybox collapses and blackbox rises, but 86% of the deep tier is not research (news, advisories, TI)

The militarisation of capability

The offensive economy is a stack, a $\sim 2000\times$ spread, with effort descending toward the softer tiers.

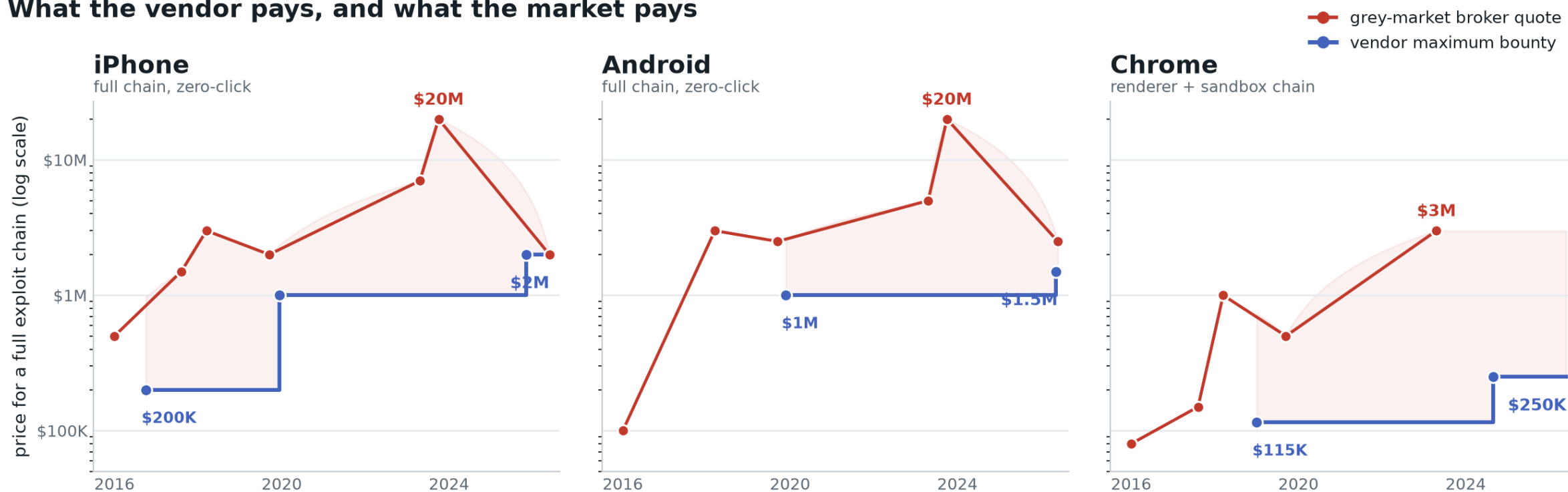


The targeted economy is a stack, a $\sim 2000\times$ spread. The elite tier stays hard; effort is descending toward the cheaper, unhardened tiers.

The report-or-sell gap

What the vendor pays vs what the market pays, across iPhone, Android, and Chrome full chains.

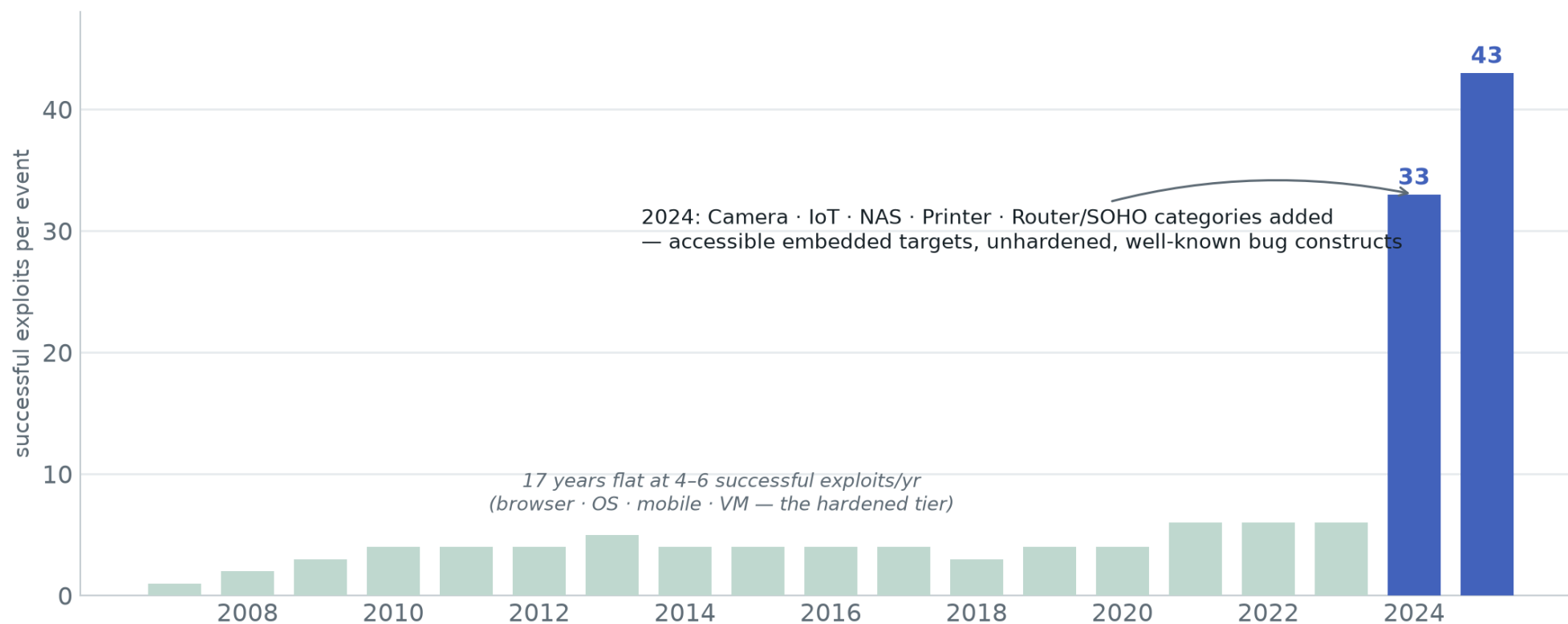
What the vendor pays, and what the market pays



Vendor figures are published maximums (rarely paid at that tier); broker figures are advertised 'up to' quotes from Zerodium, Crowdfense, and Operation Zero.

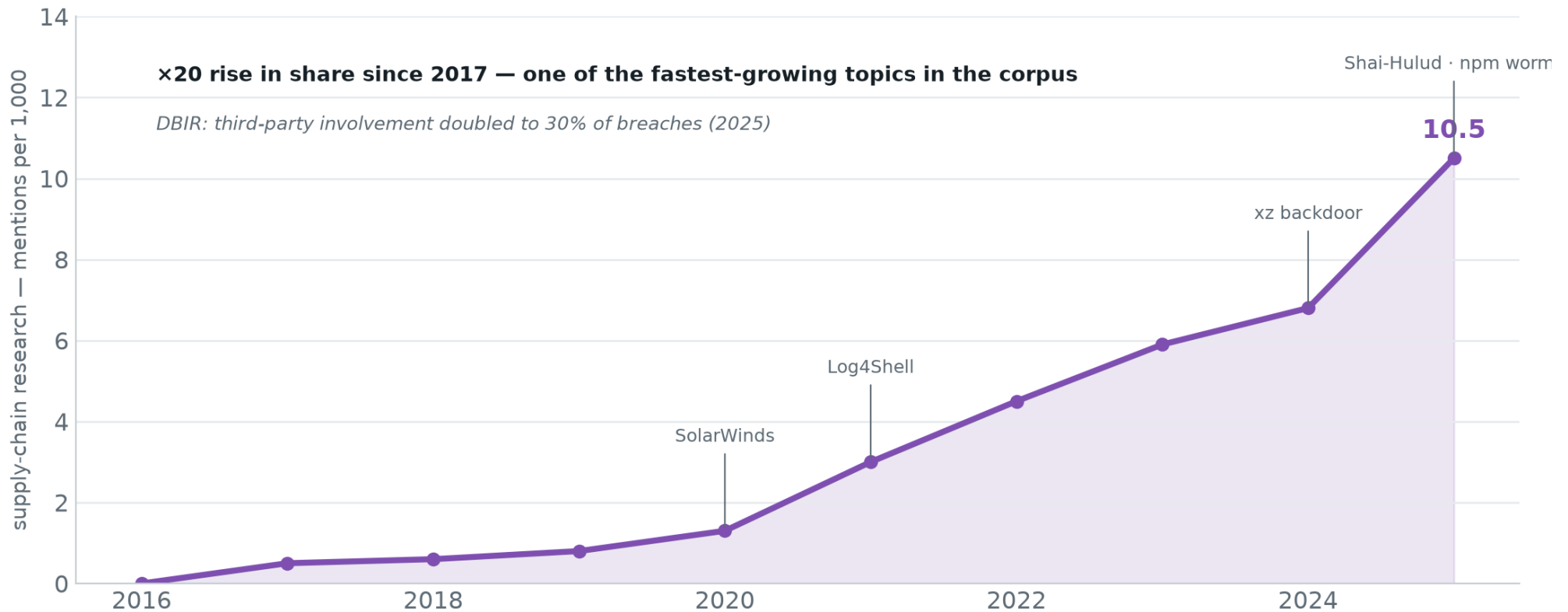
The pull of the novel over the useful

17 years flat at 4–6 Pwn2Own exploits/yr, then 33 (2024) and 43 (2025): accessibility, not capability.



Supply chain

The one front where attention has tracked reality: late, but proportionate.



AI raises the floor – so raise the foundations

Featured: Initiatives like Patch the Planet by OpenAI collaborating with industry experts are focused to uplift OSS security pragmatically

More Potential

- › Foundational, ecosystem-level work: compilers, OSeS, platforms, frameworks, libraries
- › Publish advances against whole classes: patterns, not instances
- › Novel attacks on trust boundaries: side-channels, code signing, speculative execution, sandbox escapes
- › Harden secure defaults and mitigations, then ship them past the flagship tier
- › Attack-surface reduction; kill legacy; challenge compatibility
- › Privacy and security of AI systems themselves

Note: None of this touches phishing, token theft, social engineering, or supply chain – the paths where many other compromises happen.

Three things to walk out with

- › Incentives, not threats: the field optimises for what it rewards.
- › The bugs that break in are old and understood; the research chases the novel disproportionately.
- › Aim the brains, machinery, and the AI with it, at the foundations.



Thanks for your time.

Slides and a more detailed analysis will be published soon.